Phần 1: Phân tích 2 Giải pháp Xác thực

1. Phân tích 3 yếu tố xác thực danh tính số và vai trò trong 2FA

Ba yếu tố cốt lõi trong xác thực danh tính số bao gồm:

- **Something You Know (Điều bạn biết):** Thông tin chỉ nằm trong trí nhớ người dùng. Trong hệ thống 2FA, **mật khẩu (Password) hoặc mã PIN** đại diện cho yếu tố này.
- **Something You Have (Điều bạn có):** Thiết bị vật lý hoặc đối tượng hữu hình thuộc quyền sở hữu của người dùng. Trong hệ thống 2FA, **mã OTP nhận qua điện thoại hoặc ứng dụng sinh mã** đại diện cho yếu tố này.
- **Something You Are (Điều bạn là):** Đặc điểm sinh trắc học cá nhân không thể tách rời (vân tay, khuôn mặt, mống mắt).

2. Nguyên lý hoạt động của Thuật toán TOTP (Time-based One-Time Password)

Ứng dụng Authenticator có thể sinh ra mã OTP đếm lùi 30 giây hoàn toàn chính xác ngay cả khi điện thoại đang bật **Chế độ Máy bay (hoàn toàn không có mạng Wi-Fi, 4G hay SMS)** vì các lý do kỹ thuật sau:

- **Khóa bí mật chia sẻ (Shared Secret Key):** Khi thiết lập 2FA, một khóa bí mật (dưới dạng chuỗi ký tự hoặc mã QR) đã được chia sẻ và lưu trữ an toàn một lần duy nhất giữa máy chủ (Server) và ứng dụng trên điện thoại (Client).
- **Mốc thời gian thực hiện tại (Timestamp):** Thuật toán TOTP sử dụng bộ đếm thời gian chuẩn quốc tế (Unix Epoch Time) được đồng bộ hóa nội bộ bên trong hệ thống phần cứng của điện thoại. Cứ mỗi chu kỳ **30 giây**, mốc thời gian sẽ thay đổi một lần.
- **Hàm băm mật mã (HMAC-SHA-1):** Ứng dụng kết hợp *Khóa bí mật* với *Mốc thời gian hiện tại* đưa vào hàm toán học băm mật mã để tự động sinh ra chuỗi 6 chữ số độc nhất. Do cả điện thoại và máy chủ đều dùng chung khóa và dựa vào cùng một mốc thời gian đồng hồ thời gian thực, chúng sẽ tạo ra chính xác cùng một mã số tại một thời điểm mà không cần phải truyền tải dữ liệu qua lại qua mạng viễn thông.

Phần 2: Lập bảng So sánh Trade-off & Ra quyết định

3. Bảng so sánh chi tiết giữa Giải pháp 1 và Giải pháp 2

Tiêu chí đánh giá	Giải pháp 1: SMS OTP	Giải pháp 2: TOTP Authenticator
1. Khả năng chống tấn công SIM Swapping & Nghe lén viễn thông SS7	**Kém** — Dễ bị chiếm đoạt số điện thoại hoặc nghe lén sóng mạng	**Tuyệt đối** — Khóa bí mật Shared Secret lưu an toàn trên chip điện thoại
2. Tính sẵn sàng khi Offline / Nước ngoài	Phụ thuộc sóng di động, mất sóng hoặc ra nước ngoài không nhận được mã	Hoạt động 100% Offline mọi lúc mọi nơi kể cả trên máy bay
3. Độ tiện dụng & Chi phí vận hành	Quen thuộc nhưng doanh nghiệp tốn chi phí gửi SMS viễn thông cho mỗi lượt	Miễn phí 100%, thao tác mở app quét mã nhanh chóng
4. Rủi ro khi mất điện thoại	Làm lại SIM là lấy lại được mã, nhưng nguy cơ bị kẻ xấu trộm SIM rất cao	Cần có Mã Khôi phục (Backup Codes) hoặc tính năng Cloud Sync mã hóa

4. Kết luận lựa chọn cho Ban Giám đốc PixelForge Studio

- **Lựa chọn tối ưu:** Ban Giám đốc PixelForge Studio **bắt buộc phải lựa chọn Giải pháp 2 (Authenticator App - TOTP)** cho toàn bộ đội ngũ kỹ sư.
- **Lý do lựa chọn:**
    - *Bảo vệ tài sản trọng yếu:* Tài khoản quản trị GitHub Enterprise chứa mã nguồn game trị giá hàng trăm ngàn USD, là mục tiêu tối quan trọng của hacker. SMS OTP quá dễ bị tổn thương trước các thủ thuật xã hội (Social Engineering) nhằm thực hiện tấn công **SIM Swapping** như trong bẫy dữ liệu an ninh đã cảnh báo.
    - *Đặc thù di chuyển toàn cầu:* Đội ngũ lập trình viên thường xuyên đi công tác nước ngoài (GDC) hoặc làm việc trên các chuyến bay ngắt kết nối viễn thông. Giải pháp TOTP hoạt động hoàn toàn ngoại tuyến giúp họ xác thực thông suốt mọi lúc mọi nơi mà không lo mất sóng hay tốn cước roaming.

Phần 3: Quản lý Rủi ro & Backup Codes

5. Quản lý bộ Mã Khôi phục (Backup / Recovery Codes)

- **Mục đích của bộ mã:** Dùng làm phương án dự phòng khẩn cấp giúp nhân viên đăng nhập vào hệ thống để lấy lại quyền kiểm soát khi không may **mất điện thoại, hỏng thiết bị hoặc ứng dụng Authenticator bị lỗi**.
- **2 vị trí an toàn tuyệt đối để lưu trữ:**
    - In ra giấy một bản cứng và cất giữ tại một nơi vật lý an toàn (như két sắt gia đình hoặc ngăn bàn làm việc có khóa).
    - Lưu trữ dưới dạng tệp đã được mã hóa bằng phần mềm quản lý mật khẩu cá nhân uy tín (như Bitwarden, 1Password).
- **1 sai lầm tai hại cần tránh:** Lưu trực tiếp bộ mã khôi phục dưới dạng ảnh chụp màn hình (Screenshot) hoặc tệp văn bản thuần (Plain Text) không mã hóa ngay trên máy tính cá nhân hoặc trong thư mục ảnh đồng bộ công khai (như Google Photos, iCloud công cộng). Nếu máy tính bị xâm nhập, kẻ tấn công có thể dễ dàng lấy được toàn bộ mã này và vượt qua lớp bảo vệ 2FA.